

IT 재해복구 지침



주식회사 모인

개정 이력

[illegible]

IT재해복구 지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 “회사”라 한다)에 천재지변이나 예상치 못한 사고 등과 같은 비상상황이 발생할 경우, 피해를 최소화하고 상황 악화방지 및 신속한 복구를 위한 비상대책을 마련하여 재해발생 시 서비스 중단을 최소화함을 목적으로 한다.

제2조(적용 범위) 이 지침은 회사 내에서 재해 발생 시 IT재해복구를 위한 대책수립 및 검토활동에 적용된다.

제3조(용어의 정의) 이 지침에서 사용하는 용어의 정의는 다음과 같다.

1. “재해”란 지진, 낙뢰 등의 천재지변이나 화재, 정전, 부주의 및 보안침해 등의 원인으로 정보시스템이 작동 불능 상태가 되거나 서비스가 중단되는 등 업무를 수행할 수 없는 상태를 말한다.
2. “복구목표시간(RTO: Recovery Time Objective)”이란 재해 발생 시 서비스를 복구하는데 소요되는 최대 허용 시간을 의미한다.
3. “복구목표시점(RPO: Recovery Point Objective)”이란 재해 발생으로 인해 중단된 서비스를 복구하였을 때, 유실을 감내할 수 있는 데이터의 손실 허용시점을 말한다.
4. “DR센터(또는 재해복구센터)”란 주 전산센터의 재해 발생에 대비하여 업무 연속성을 보장할 수 있도록 원격지에 구축한 전산센터로서 원격지 센터, 백업센터를 말한다.

제2장 역할 및 책임

제4조(IT재해복구 책임자)

- 1 IT재해복구 책임자는 IT재해복구 계획에 대한 정책을 수립하고 정책의 이행을 위하여 필요한 자원을 지원할 책임을 가진다.
- 2 IT재해복구 책임자는 IT재해복구 관련 업무와 조직을 지휘하여야 하며, 재해 발생 시 대응 추진 상황을 점검하여야 한다.
- 3 IT재해복구 책임자는 IT재해복구 모의훈련 계획을 수립 및 검토하여야 하는 책임을 가진다.

제5조(IT재해복구 담당자)

- 1 IT재해복구 담당자는 업무 연속성을 훼손할 수 있는 재해를 식별하고 발생에 따른 영향을 분석해 업무중요도 평가를 수행하여야 한다.
- 2 재해발생 시 유관기관에 연락 및 절차에 따라 대응하여야 하는 책임을 가진다.
- 3 IT재해복구 책임자의 지휘에 따라 재해 발생 시 IT재해복구와 관련된 부서에게 필요한 사항을 요구할 수 있다
- 4 IT재해복구 담당자는 IT재해복구 모의훈련을 수행하여야 하는 책임을 가진다.

제6조(IT재해복구조직)

- 1 IT재해복구조직에 소속된 구성원들은 평상시 및 재해 발생시의 책임과 역할을 충분히 인지하여야 한다.
- 2 IT재해복구조직은 사전에 위험을 인지하고 관련된 위험을 줄이며, 재해 발생시 피해를 줄이고 중요 기능의 신속한 복구를 보장하기 위한 통제들을 시행하여야 한다.
- 3 IT재해복구조직은 필요 시 IT재해복구 절차를 수정하고 관련문서를 즉시 갱신하여 관리한다.
- 4 재해 발생시 필요한 경우 회사 내에 재해 발생 사실을 선포하여 전 직원이 이를 인지할 수 있도록 하며 IT재해복구 업무를 수행한다.
- 5 IT재해복구조직은 재해 발생시의 대응지침을 각 부서에 전달하고 이를 따르도록 요구할 수 있다.

제3장 IT재해복구 대책 수립

제7조(재해 분류) IT재해복구 담당자는 업무의 연속성을 훼손할 수 있는 재해 위험요인을 식별하여야 한다. 재해 위험요인은 다음 각 호와 같다.

- 1) 자연재해: 화재, 홍수, 지진, 태풍 등
- 2) 외부요인: 해킹, 통신장애, 전력 수급 중단 등
- 3) 내부요인: 시스템 결함, 기계적 오류, 사용자 실수, 의도적·악의적 운영, 파업, 핵심 운영자 근무 이탈(사망, 병가, 휴가, 이직 등), 환경설정 오류 등

제8조(IT재해복구 대책 수립)

- 1 IT재해복구 책임자는 재해발생 시 장애, 재해, 파업, 전자적 침해 등 재해의 유형에 따른 복구 절차 및 서비스 중단을 최소화하기 위한 다음 각 호의 내용을 포함한 IT재해복구 대책을 수립하여야 한다.
 - 1) 상황별 대응절차
 - 2) 백업 또는 재해복구센터를 활용한 재해복구 계획
 - 3) 비상대응조직의 구성 및 운용
 - 4) 입력대행, 수작업 등의 조건 및 절차

- 5) 모의훈련의 실시
 - 6) 유관기관 및 관련업체와의 비상연락체제 구축
 - 7) 보고 및 대외통보의 범위와 절차 등
- 2 재해 발생으로 인하여 업무 중단 시 각 업무별 피해규모 및 업무 중요도를 파악하여 회사 본업과 관련된 핵심업무를 선정하고, 최소 업무복구 목표시간(RTO)와 복구목표시점(RPO)을 정한다.
- 3 사전 정의한 핵심 업무의 복구목표시간은 3시간 이내, 복구목표시점은 데이터의 손실 없이 복구하는 것을 목표로 복구 전략 및 대책을 수립하여야 한다.

제9조(IT재해복구 조직) 회사는 비상사태가 발생하는 경우 위험을 최소화하고 신속한 복구 및 업무 연속성을 보장하기 위해 IT재해복구 책임자 책임자로 하는 IT재해복구 조직을 구성하여야 한다.

제10조(DR센터 운영) 주 전산센터의 장애 또는 재해 발생에 대비하여 DR센터를 운영하고, IT재해복구 담당자는 다음 각 호의 사항을 통해 DR센터를 관리하여야 한다.

- 1. DR센터의 전산설비가 정상적인 작동 상태를 유지할 수 있도록 분기마다 점검을 실시한다.
- 2. 주 전산센터와 DR센터 간 네트워크의 정상적인 작동 여부를 지속적인 모니터링을 통해 장애 발생에 대비한다.
- 3. DR센터의 출입통제 및 시설관리에 관한 사항은 「물리적보안지침」에서 정한 전산실에 대한 보안대책을 준용한다.

제11조(비상지원인력 관리)

- 1 회사는 파업 등의 비상상황 발생 시 정보처리시스템을 정상적으로 운영하기 위한 비상지원인력을 확보하여야 한다. 다만, 비상지원인력 확보와 관련하여 외부 전문업체를 활용하는 방안을 수립·운영할 수 있다.
- 2 회사는 비상 시 원활한 지원이 가능하도록 비상지원인력에게 운영에 대한 교육 및 연수 방안을 마련하여야 한다.
- 3 회사는 비상지원인력이 사용법을 충분히 이해하고 업무운용이 가능한 수준으로 전산시스템 운영지침서, 사용자매뉴얼 등을 쉽고 자세하게 작성하고 최신상태로 유지하여야 한다.

제4장 IT재해복구 절차

제12조(재해발견) 회사의 중요한 업무 일부 또는 전부가 마비될 정도의 피해가 우려되는 사태가 발생하거나 예견되는 경우, 이를 발견한 임직원은 정보보안팀에 즉시 연락하여 재해의 선포를 가능하도록 하여야 한다.

제13조(재해선포)

- 1 재해로 인한 업무 중단사태가 발생하면 IT재해복구조직은 비상연락에 의거하여 신속하게 연락을 취하고 다음 각 호의 상황을 공유한다.
 - 1) 재해발생 일시, 재해 유형 등 재해발생내역
 - 2) 인적/물적 피해 정도를 포함한 대략적인 피해 규모
 - 3) 비상소집 일정 및 장소
- 2 IT재해복구 책임자는 재해발생 시 DR센터로의 전환 여부를 결정하기 위하여 다음 각 호의 사항을 포함하여 피해상황을 파악하여야 한다.
 - 1) 재해의 원인
 - 2) 추가적인 피해 잠재성
 - 3) 피해지역 및 설비상태
 - 4) IT 가용자원 파악
 - 5) IT 자원 및 데이터의 피해 종류
 - 6) 재해로 인한 예상 중단 지속시간
- 3 IT재해복구 책임자는 다음 각 호의 사항을 종합적으로 고려하여 재해 선포 여부 결정한다.
 - 1) 인적/물적 피해의 정도
 - 2) 재해의 파급효과 정도(물리적, 운영상의 피해, 피해금액 등)
 - 3) 업무 시스템의 중요성
 - 4) 장애의 지속시간

제14조(IT재해복구 절차의 실행)

- 1 IT재해복구 책임자는 재해가 선포되면 비상연락망을 통해 IT재해복구조직을 소집하여 상황에 따른 IT재해복구 절차를 실행되도록 한다.
- 2 IT재해복구 담당자는 필요한 경우 유관기관에 재해발생 사실을 보고하여야 한다.
- 3 IT재해복구조직은 관련 팀의 리더에게 통보하여 IT재해복구 절차가 실행되도록 한다. 다만, 긴급한 경우 관련 팀의 리더는 자체 판단에 따라 IT재해복구 절차를 우선 실행하고 IT재해복구조직에 통보할 수 있다.
- 4 IT재해복구 책임자는 피해의 파급 효과 및 피해 상황을 파악하여 DR센터로의 전환 여부를 결정하여야 한다.
- 5 IT재해복구조직은 피해상황에 대하여 복구 우선순위가 높은 순으로 IT재해복구 절차에 따라 복구를 실시한다.
- 6 IT재해복구조직은 복구된 서비스의 정상적인 동작을 확인하면 재해 상황을 종료하고 관련 기관 및

임직원에게 알리도록 한다.

제15조(IT재해복구 절차의 갱신)

- 1 IT재해복구 책임자는 IT재해복구 계획의 효율성과 효과성을 보장하기 위해서 IT재해복구 절차에 대하여 매년 1회 이상 정기적으로 검토하고 갱신하여야 한다.
- 2 조직의 변경, 중요한 업무프로세스 또는 정보시스템의 변경, 새로운 장비의 도입 등의 경우에 IT재해복구절차의 유효성이 상실되지 않도록 필요한 경우 적시에 갱신 및 버전관리를 하여야 한다.

제16조(비상연락망 관리)

- 1 IT재해복구 담당자는 장애 또는 재해로 인하여 업무가 중단되었을 경우 임직원, 이용기관, 유관기관 및 공급업체(벤더) 등과 긴급 연락 및 긴밀한 협조 체제를 위해 비상연락망을 관리하여야 한다.
- 2 IT재해복구 담당자는 비상연락망이 항상 최신의 정보가 반영될 수 있도록 관리하여야 한다.

제5장 IT재해복구 모의훈련

제17조(모의훈련 목적 및 범위)

- 1 IT재해복구를 위한 모의훈련의 목적은 다음 각 호와 같다.
 - 1) IT재해복구 수행능력 향상 및 훈련 실시결과 평가를 통한 개선
 - 2) IT재해복구 취약성 및 필요 자원 부족 등 파악
 - 3) 비상상황 대응능력 향상, 관련 부서간 협조 및 의사소통 개선
- 2 IT재해복구를 위한 모의훈련의 범위는 다음 각 호와 같다.
 - 1) IT재해복구 전략
 - 2) 비상상황별 비상대응 절차
 - 3) 비상상황별 업무복구 및 복원 절차 등

제18조(모의훈련 계획 수립) IT재해복구 책임자는 DR센터 전환 훈련 등을 포함한 IT재해복구 모의훈련 계획을 다음 각 호의 사항을 고려하여 연 단위로 수립한다.

- 1) 훈련목표, 유형, 일정
- 2) 시간대별 절차 및 참가자
- 3) 소요예산 등

제19조(모의훈련 수행) IT재해복구 담당자는 다음과 각 호의 사항을 고려하여 연간 모의훈련 계획에 따라 매년 1회 이상 모의훈련을 실시한다.

- 1) 시스템의 효율적 복구를 위한 기술적 복구 테스트
- 2) 전자적 침해사고(해킹, 서비스거부 공격 등)에 대비한 테스트
- 3) 업무 및 사건·사고 시나리오에 의한 사고(思考) 테스트(Table-top testing)
- 4) 중요 장애에 대응할 수 있는 능력의 확보를 위한 비상대응 세부조직 소집 테스트
- 5) 비상상황에 대비하기 위한 DR센터로의 전환 테스트

제20조(모의훈련 평가 및 보고)

- 1 IT재해복구 담당자는 훈련 참가자들의 평가를 포함한 모의훈련 결과보고서를 작성하여 IT재해복구 책임자의 승인을 득한 후 금융위원회에 보고하여야 한다.
- 2 IT재해복구 책임자는 모의훈련 결과 분석에 따라 도출된 문제점 및 개선방안은 IT재해복구 지침 및 복구 절차에 반영하고, 필요에 따라 구성원들에게 교육을 실시하여야 한다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.